CASE STUDY

# CVE-2026-123039 and Root on the Check Point Gateway: The PHP2Shell Chain, the TSGA Implant and the ESXi Wiper of October and November 2026

*A TeamStarWolf case study. Published 13 November 2026; every source checked as of that date.*

## Executive summary

For the people who run Check Point firewalls, the week of 30 October 2026 came down to one question: was the Mobile Access portal patched in time? Where it was not, an attacker exploited PHP2Shell (CVE-2026-109618 and CVE-2026-109619) on the portal, became the portal's service account, and then used a second flaw, not yet public at the time, to become root [5] (**Confirmed**; 'not yet public' **Inferred** from [1] [3]). That second flaw is CVE-2026-123039. Check Point published it as the CNA on 12 November 2026, two weeks after the first attack wave [1] [5] (**Confirmed**).

CVE-2026-123039 is a local privilege escalation in Gaia OS, the operating system under Check Point's gateways and management servers. The DynamicCLI daemon runs as root and listens on a world-writable local socket without checking who connects to it. Any authenticated local user can hand it a command and have that command run as root [1] [3] (**Confirmed**). The CNA scored it CVSS 3.1 7.8, local attack vector, and assigned CWE-862 Missing Authorization and CWE-732 Incorrect Permission Assignment for Critical Resource [1] (**Confirmed**). Check Point says it saw active exploitation against "a couple of dozen customers" [3] (**Confirmed**). The flaw was exploited before any fix or public record existed, which makes it a zero-day in practice, although neither Check Point document uses that word (**Inferred** from [1] [3] [5]).

What came after root is the reason this study exists. Check Point Research (CPR) describes web shells planted in the portal's login templates, a Check Point-aware implant called TSGA that runs under a name

resembling a Check Point process, a proxy library called TSProxy injected into appliance processes, the gogo scanner run from the gateway, and a hop over SSH to a VMware ESXi host using the vCenter service account vpxuser. On that host, in the first wave of 30 October against Israeli organizations, a wiper called destroy_v6 deleted files and left a political note in Hebrew [5] (**Confirmed**). A second, broader wave on 2 November hit organizations in multiple countries with no destruction reported [5] (**Confirmed**).

The attribution is open. TSGA and TSProxy are modified variants of PhiliKit, an implant that ESET assesses as part of UNC5221's SPAWN toolset [12], a group CPR describes as China-nexus [5] (**Confirmed**). Yet CPR names three attributes that do not appear to fully align with that group, including the destruction and the Hebrew note, and declines to make a high-confidence assessment [5] (**Confirmed**).

## Key facts at a glance

| Field | Value |
|---|---|
| Flaw | Local privilege escalation to root in the Gaia OS DynamicCLI daemon through a world-writable local control socket that does not authenticate callers [1] [3] |
| Weaknesses | CWE-862 Missing Authorization; CWE-732 Incorrect Permission Assignment for Critical Resource (CNA; NVD carries the same) [1] [2] |
| Score | CVSS 3.1 7.8 High, AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H (CNA). NVD status "Awaiting Analysis" on 13 Nov 2026 [1] [2] |
| Precondition | The attacker must already have local code execution on the appliance [3] |
| Affected products | Force Firewalls; Management and Log Servers; Multi-Domain Security Management and Multi-Domain Log Server; Maestro Orchestrator. Not affected: Spark Firewalls, Smart-1 Cloud [3] |
| Fixed | Jumbo Hotfix Accumulator R82.20 Take 14, R82.10 Take 52, R82 Take 132, R81.20 Take 174. R81.10 and R81 (end of support): affected, no fixed Take [3] |
| Disclosed | CVE reserved 5 Nov 2026; sk1000362 created 8 Nov; CVE published 12 Nov 2026 14:02 UTC [1] [3] |
| Exploited | Yes: "a couple of dozen customers" (vendor) [3]; exploited in the wild, per Check Point as relayed by the Canadian Centre for Cyber Security [6] |
| KEV | Added 13 Nov 2026 in catalog version 2026.11.13, due 16 Nov 2026 under BOD 26-04, ransomware use Unknown; the PHP2Shell pair was added 26 Oct 2026 [7] |
| Campaign | Wave 1, 30 Oct 2026: Israeli organizations, destructive at some. Wave 2, 2 Nov 2026: multiple countries and sectors, no destruction reported [5] |
| Chain | PHP2Shell on Mobile Access portals, then CVE-2026-123039 to root, then web shells, TSGA and TSProxy, gogo scanning, SSH to ESXi as vpxuser, destroy_v6 wiper [5] |
| Attribution | Tooling lineage to PhiliKit (ESET: UNC5221); CPR makes no high-confidence assessment [5] [12] |

## Key findings

- **A local bug became a remote root chain.** CVE-2026-123039 needs code execution first [3] (**Confirmed**). PHP2Shell on an internet-facing Mobile Access portal supplied it [5] (**Confirmed**). Read alone, the 7.8 score understates what the flaw did in this campaign (**Inferred** from [1] [3] [5]).

- **It was exploited before it had a name.** The first wave ran on 30 October and the second on 2 November [5]. The CVE was reserved on 5 November and the support article created on 8 November [1] [3] (**Confirmed**). Defenders had no record to act on during either wave (**Inferred**).
- **The patch gap on the portal was about a week.** CPR says the first wave began roughly one week after a security fix became available [5] (**Confirmed**). CISA's federal due date for the PHP2Shell pair was 29 October, the day before [7] (**Confirmed**).
- **The implant was built for the appliance.** TSGA steals configurations, persists through backups and snapshots, injects into processes and tampers with binary firewall logs [5] (**Confirmed**). A post-compromise backup is not a safe restore point, and on-box logs are not trustworthy (**Inferred** from [5]).
- **The firewall reached the hypervisor.** The attacker moved from the gateway to ESXi over SSH as vpxuser and ran the wiper there [5] (**Confirmed**). The edge device was one hop from the virtualization layer (**Inferred**).
- **The record does not line up.** The CVE record's "or below" ceilings and the support article's first fixed Takes leave R82.20 Takes 11 to 13, R82.10 Take 51 and R82 Take 131 unclassified. The CVE record also leaves out R81.10 and R81, which the support article lists as affected [1] [3] (**Inferred** from **Confirmed** records).
- **Old releases have no fix.** R81 left support in October 2024 and R81.10 in March 2026. sk1000362 lists both as affected with no fixed Take [3] [20] (**Confirmed**).
- **The attribution is honestly uncertain.** Shared code, keys and a TLS certificate tie TSGA and TSProxy to PhiliKit [5] (**Confirmed**). CPR still lists a single actor, an access broker, a false flag and a smoke screen as possible readings [5] (**Confirmed**). One news report credits ESET with the actor name "Armory Castle"; ESET's report says UNC5221, and the library records the Armory Castle name as Google's [44] [12] [50] (**Reported**).

## Top recommendations

1. Install the fixed Jumbo Hotfix Take from sk1000362 on every affected Gaia system, management servers and Maestro Orchestrators as well as gateways. Go by the support article's Takes, not the CVE record's ranges [1] [3] (**Confirmed** facts; the priority **Inferred**).
2. Patch both Gaia flaws published on 12 November: CVE-2026-123039 (sk1000362) and CVE-2026-107484 (sk1000291) [6] [8] (**Confirmed**).
3. On R81 and R81.10, plan the upgrade now. Until then, apply the vendor's interim mitigation, which stops the Dynamic CLI process and accepts that the Dynamic CLI commands stop working [3] [20] (**Confirmed** facts; the course of action **Inferred**).
4. Close the entry point. Patch PHP2Shell on every Mobile Access gateway, and limit portal exposure where it is not needed [5] [9] (**Confirmed** entry point; controls **Inferred**).
5. Hunt on every gateway and cluster member: the DynamicCLI log as sk1000362 describes, the CPR file names and hashes, web shells in the portal template directory, the TSGA listening port and the two attacker addresses [3] [5] (**Confirmed**).
6. If you find anything, rebuild from a clean image of a fixed release rather than a backup or snapshot taken after compromise. Rotate credentials and certificates, re-issue VPN trust and check every ESXi host the

gateway could reach (**Inferred** from [5] [40]).

7. Break the path from firewall to hypervisor: ESXi SSH off, lockdown mode on, and a management network the gateway cannot reach [37] (**Confirmed** for the ESXi controls; the design **Inferred**).
8. Treat the KEV deadline as the floor, not the trigger. The vendor said the flaw was exploited on 12 November, the Canadian Centre relayed that the same day, and CISA added it to KEV on 13 November with a 16 November due date under BOD 26-04 [3] [6] [7] (**Confirmed**).

## Scope and method

This study covers CVE-2026-123039 from the first documentation of Dynamic CLI in 2019 to the record as it stood on 13 November 2026, and the campaign CPR reported on 12 November 2026. It is the library's home for CVE-2026-123039, the TSGA and TSProxy implants, the destroy_v6 wiper and the attribution discussion. The PHP flaws themselves live in PHP2Shell and the October 2026 Attack Wave, and CVE-2026-50751 lives in the Check Point VPN IKEv1 study [51] (**Confirmed**). Each is summarized here in one paragraph.

This is not a lab study. Nothing was reproduced. Tradecraft is described at the level the advisories use. The socket path and message format, web shell contents and keys, hunting command strings, the wiper note's text and any proof-of-concept detail are left out. Indicators appear as the vendor publishes them: file names, SHA-256 hashes, one port and two defanged IP addresses.

| Grade | Meaning in this study |
|---|---|
| Confirmed | Stated in a primary record opened for this study: the CVE and NVD records, Check Point's support articles and research report, government advisories and catalogs, vendor documentation, and the library's own data files |
| Reported | Stated only by a secondary source (a news report), or a third party's claim this study could not test against a primary |
| Inferred | This study's own reasoning from cited facts, labelled where it appears |

The primary record is the CVE record [1], sk1000362 [3] and the CPR report [5]. The Team Star Wolf Intelligence Hub feed served as a starting index of dated headlines; no fact here rests on it [52]. The press is secondary. Where a news report says more than the primaries, the extra claim is graded Reported and attributed.

Not checked: the body of sk144112, which needs a login, so the list of Dynamic CLI commands the mitigation disables is not known here [4]; national CERT notices other than the Canadian Centre, CSIRT Italia and CERT-EU, including NCSC UK, ACSC, BSI, JPCERT and the Israel National Cyber Directorate; Dream Security's own write-up of the Palo Alto Networks intrusions beyond the post cited [31]; and any primary source on EDR support for Gaia. No victim is named in any source opened for this study.

# Part 1: the vulnerability record

## What Dynamic CLI is

Gaia is Check Point's unified security operating system. It combines Check Point's original operating systems with IPSO and runs on all Check Point Security Appliances and Open Servers [15] (**Confirmed**). Its command-line shell is Gaia Clish, which sk144112 extends with Expert mode commands [4] (**Confirmed**). sk144112, "Dynamic CLI: Enhancing Gaia Clish with new Expert mode commands", was created on 8 January 2019 and last modified on 29 December 2025. It applies to R82.10, R82, R81.20, R81.10 (end of support) and R81 (end of support) [4] (**Confirmed**). The feature has been documented since at least 2019 [4] (**Confirmed**). Whether the exposure is as old as the feature is not stated by the vendor and is not assumed here.

## The flaw

The CVE record's title is "Local privilege escalation to root in the DynamicCLI daemon via local world-writable control socket" [1] (**Confirmed**). sk1000362 uses the same title with "process" for "daemon" [3] (**Confirmed**). In functional terms: the Gaia dynamic CLI is served by a root process, named in sk1000362 as dynamic_server, that listens on a local IPC socket. On affected releases that socket is world-writable and the process does not authenticate whoever connects. Any command string it receives runs as root [1] [3] (**Confirmed**).

Two weaknesses describe it. The socket's permissions are wrong (CWE-732), and the daemon never asks whether the caller is allowed (CWE-862) [1] (**Confirmed**). Either control alone would have stopped a low-privilege caller (**Inferred**).

The prerequisite matters. sk1000362 says exploitation requires the attacker to already have local code execution on the appliance [3] (**Confirmed**). The CVE record says "an authenticated local user" [1] (**Confirmed**). In the campaign that local user was the Mobile Access portal's service account, reached through PHP2Shell [5] (**Confirmed**).

## Scores and catalog state

| Record | State on 13 Nov 2026 | Sources | Grade |
|---|---|---|---|
| CVE record | PUBLISHED by CNA Check Point. Reserved 2026-11-05T07:30:18Z, published 2026-11-12T14:02:13Z, not updated since. Only reference: sk1000362 | [1] | Confirmed |
| CNA score | CVSS 3.1 7.8 High, CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H | [1] | Confirmed |
| NVD | Published 2026-11-12T14:17:24, last modified 20:04:52, "Awaiting Analysis". Carries only the CNA's (Secondary) score and CWEs; no NVD score, no CPE configuration | [2] | Confirmed |
| sk1000362 | Created 2026-11-08, last modified 2026-11-12, CVSS 7.8 | [3] | Confirmed |
| CISA KEV | Added 13 Nov 2026 in catalog version 2026.11.13 (the 2026.11.10 version, current at publication, did not list it); due 16 Nov 2026; required action under BOD 26-04 with forensic triage; ransomware use Unknown | [7] | Confirmed |
| Canadian Centre | AV26-1154, 12 Nov 2026: Check Point indicates CVE-2026-123039 is exploited in the wild | [6] | Confirmed |

## Products and versions

sk1000362 lists four affected product families: Force Firewalls; Management and Log Servers; Multi-Domain Security Management and Multi-Domain Log Server; and Maestro Orchestrator. It lists Spark Firewalls and Smart-1 Cloud as not affected [3] (**Confirmed**). The CVE record names two products, Quantum Security Gateway and Quantum Security Management [1] (**Confirmed**). The management plane is in scope, not only gateways [3] (**Confirmed**).

| Release | CVE record: affected | sk1000362: first fixed Take | Unclassified Takes | Support ends |
|---|---|---|---|---|
| R82.20 | Take 10 or below | Take 14 | 11 to 13 | September 2030 |
| R82.10 | Take 50 or below | Take 52 | 51 | June 2030 |
| R82 | Take 130 or below | Take 132 | 131 | April 2029 |
| R81.20 | Take 173 or below | Take 174 | none | May 2027 |
| R81.10 | not listed | affected, end of support, no fix | none (the CVE record omits the release; sk1000362 lists it affected) | March 2026 (passed) |
| R81 | not listed | affected, end of support, no fix | none (the CVE record omits the release; sk1000362 lists it affected) | October 2024 (passed) |

Sources for the table: the CVE record [1], sk1000362 [3] and Check Point's support periods page [20] (**Confirmed**). The "Unclassified Takes" column is this study's reading: neither record says whether those Takes are affected (**Inferred**). The support article governs, so patch to at least its Take [3] (**Inferred**).

Check Point's Release Map recommends R82.10 with its latest Jumbo Hotfix Take for all deployments. R82.20, released on 8 September 2026, can be upgraded to from R81, R81.10, R81.20, R82 and R82.10 [22] (**Confirmed**). A Jumbo Hotfix Accumulator bundles "important security, hardening, stability, and product fixes". Each release is a numbered Take, and each Take is "considered Recommended from the day of its release". Accumulators for R81.10 and earlier were cancelled because those versions are end of support [19] (**Confirmed**).

## Why Spark and Smart-1 Cloud are out

Every Spark Firewall firmware image is based on Gaia Embedded OS, which is built from the main Gaia code line and synced with it periodically. Spark has capabilities of its own, and some capabilities exist only in the main line [16] (**Confirmed**). Smart-1 Cloud is a management service hosted entirely in the cloud with "Zero Maintenance" for the customer [17] (**Confirmed**). The not-affected list matches that split: Spark does not run full Gaia, and Smart-1 Cloud customers do not administer the OS (**Inferred** from [3] [16] [17]).

## The sibling flaw

Check Point published CVE-2026-107484 at 14:01 UTC on 12 November 2026, one minute before CVE-2026-123039 [8] (**Confirmed**). The Canadian Centre describes it as an input validation flaw in Gaia Portal backend handlers [6]; the CVE record says it lets an authenticated non-admin user escalate privileges [8] (**Confirmed**). It carries CWE-269 and a CVSS 3.1 vector of AV:A/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N, with sk1000291 as its article [8] (**Confirmed**). AV26-1154 covers both CVEs and makes no exploitation statement for CVE-2026-107484 [6] (**Confirmed**).

## Discrepancies in the record

- **Version ceilings.** The gaps in the table above sit between the CVE record and sk1000362 [1] [3] (**Inferred** from **Confirmed** records).
- **End-of-support releases.** sk1000362 lists R81.10 and R81 as affected; the CVE record does not list them at all [1] [3] (**Confirmed**). A scanner driven only by the CVE record could report an R81.10 gateway as clean (**Inferred**).
- **Product names.** The CVE record uses Quantum Security Gateway and Quantum Security Management; sk1000362 and AV26-1154 use four product families [1] [3] [6] (**Confirmed**). BleepingComputer lists Firewall, MDSM, Scalable Platforms, Security Gateway and Security Management Server, and says nothing about R81, R81.10, Spark or Smart-1 Cloud [42] (**Reported**).
- **"Zero-day".** BleepingComputer's headline calls it a zero-day flaw exploited for root access [42] (**Reported**). Neither the CVE record nor sk1000362 nor the CPR report uses the word, and CPR does not date the escalation step separately or give a customer count for it [1] [3] [5] (**Confirmed**). The dates support the label in practice (**Inferred**, see Part 2).

## Part 2: the timeline

| Date | Event | Sources | Grade |
|---|---|---|---|
| 8 Jan 2019 | sk144112 documents Dynamic CLI, the Gaia feature served by the vulnerable daemon | [4] | Confirmed |
| 8 Feb 2023 | CISA AA23-039A: ESXiArgs ransomware encrypted configuration files on more than 3,800 ESXi servers | [35] | Confirmed |
| 13 Jun 2023 | Mandiant explains vpxuser and how UNC3886 harvested its credentials after rooting vCenter; CISA issues BOD 23-02 on internet-exposed management interfaces | [33] [38] | Confirmed |
| 7 Apr 2024 | Earliest exploitation attempts against Check Point CVE-2024-24919, as later traced by the vendor | [23] | Confirmed |
| 30 May 2024 | CVE-2024-24919 enters KEV, ransomware use Known | [24] | Confirmed |
| Oct 2024 | R81 reaches end of support | [20] | Confirmed |
| 22 Jan 2025 | CISA and FBI AA25-022A on chained Ivanti Cloud Service Appliance flaws; the actors used the Obelisk and GoGo scanners | [34] | Confirmed |
| 4 Feb 2025 | CISA and partners release the edge-device guidance series, including the Canadian Centre's ITSM.80.101 | [39] [40] | Confirmed |
| 25 Feb 2026 | A PhiliKit sample named "philistine" is uploaded to VirusTotal from South Korea | [5] [13] | Confirmed |
| Mar 2026 | R81.10 reaches end of support | [20] | Confirmed |
| 28 May 2026 | ESET's APT Activity Report assesses PhiliKit as part of UNC5221's SPAWN toolset | [12] | Confirmed |
| 8 Jun 2026 | Check Point CVE-2026-50751 (IKEv1 bypass) published and added to KEV | [26] [7] | Confirmed |
| 22 Jul 2026 | Check Point CVE-2026-16232 (SmartConsole login bypass) published and added to KEV the same day | [25] | Confirmed |
| 23 Jul 2026 | Pinpointed zero-day attacks on CVE-2026-93616, a path traversal in the Management web service | [29] | Confirmed |
| 9 to 10 Sep 2026 | Check Point updates for CVE-2026-85102 and CVE-2026-85103; CERT-EU 2026-012; Canadian Centre AV26-902 | [11] [27] | Confirmed |
| 12 Sep 2026 | Attack waves on CVE-2026-85102 begin | [29] | Confirmed |
| 17 Sep 2026 | Canadian Centre AV26-933 on CVE-2026-91843 in Security Management and Log Servers | [28] | Confirmed |
| 22 Sep 2026 | CVE-2026-85102 and CVE-2026-93616 enter KEV | [7] [27] | Confirmed |

| Date | Event | Sources | Grade |
|---|---|---|---|
| 21 Oct 2026 | PHP2Shell patches released, per a news report; GreyNoise's PHP2Shell sensor data starts | [43] [14] | Reported / Confirmed |
| 23 Oct 2026 | CERT-EU 2026-018 covers the PHP flaws. Dream Security reports the first government PAN-OS firewall rooted through PHP2Shell and Fragnesia | [10] [31] | Confirmed / Reported |
| 26 Oct 2026 | KEV adds CVE-2026-109618 and CVE-2026-109619, due 29 Oct, with forensic triage required. Dream Security publishes its PAN-OS chain report | [7] [31] | Confirmed / Reported |
| 28 Oct 2026 | GreyNoise records its first successful PHP2Shell exploitation of a vulnerable sensor. KEV adds VMware ESX CVE-2026-41709 | [14] [36] [7] | Confirmed |
| 29 Oct 2026 | KEV due date for the PHP2Shell pair. A news report lists "Armory Castle (formerly UNC5221)" among the names for Warp Panda | [7] [45] | Confirmed / Reported |
| 30 Oct 2026 | First wave from 130.94.19[.]204 against unpatched Mobile Access portals of Israeli organizations, about one week after a fix; first signs of exploitation (PHP session artifacts, hundreds of portal worker crashes). In the investigated intrusion, CPR then describes escalation with CVE-2026-123039, web shells, TSGA, TSProxy, gogo, SSH to ESXi as vpxuser and destroy_v6, without dating each step | [5] | Confirmed |
| 2 Nov 2026 | Second, broader wave across multiple countries and sectors, including some first-wave Israeli targets; no destruction reported | [5] | Confirmed |
| 5 Nov 2026 | CVE-2026-123039 reserved | [1] | Confirmed |
| 8 Nov 2026 | sk1000362 created | [3] | Confirmed |
| 9 Nov 2026 | CSIRT Italia AL05/261109 on Check Point PHP2Shell updates marks exploitation present; it does not mention CVE-2026-123039 | [9] | Confirmed |
| 10 Nov 2026 | KEV catalog version 2026.11.10 released, without CVE-2026-123039 | [7] | Confirmed |
| 12 Nov 2026 | CVE-2026-107484 published (14:01 UTC) and CVE-2026-123039 published (14:02 UTC). NVD receives the record (14:17). CPR publishes its report. sk1000362 last modified. Canadian Centre issues AV26-1154 | [1] [2] [3] [5] [6] [8] | Confirmed |
| 13 Nov 2026 | Press coverage. NVD still "Awaiting Analysis"; CISA adds CVE-2026-123039 to KEV in catalog version 2026.11.13, due 16 Nov under BOD 26-04; no Sigma rule for the campaign in the SigmaHQ repository | [2] [7] [41] [42] [43] [44] [46] | Confirmed / Reported |

**Reading the dates.** Exploitation of CVE-2026-123039 happened no later than the waves of 30 October and 2 November. The CVE was reserved on 5 November and the support article created on 8 November. The flaw was therefore exploited before any fix or public record existed [1] [3] [5] (**Inferred**). BleepingComputer says exploitation began in late October [42] (**Reported**), which agrees.

# Part 3: the campaign chain

## Initial access: PHP2Shell on the Mobile Access portal

The library's home for the PHP flaws is PHP2Shell and the October 2026 Attack Wave. In brief: CVE-2026-109618 and CVE-2026-109619 affect PHP 5.4 to 8.5 and were fixed in 8.5.12, 8.4.27, 8.3.36 and 8.2.35 [51] (**Confirmed**). The library records their weaknesses as CWE-416, CWE-755, CWE-824, CWE-1325 and CWE-1419 in PHP 8.4.27 CVEs, matching KEV [49] [7] (**Confirmed**). KEV added both on 26 October with a 29 October due date and ransomware use Unknown [7] (**Confirmed**). GreyNoise's sensors, from 21 October to 13 November, saw 726 attacker addresses, 259,565 sessions and 222,294 exploitation attempts, with 1,229 successful exploitations of its vulnerable sensors from 24 addresses, the first on 28 October; its page does not mention Check Point [14] (**Confirmed**). Dream Security reports the same pair, chained with the Linux kernel flaw Fragnesia (CVE-2026-46300), rooting 25 PAN-OS firewall and management servers [31] (**Reported**).

On Check Point, the Mobile Access Software Blade gives Remote Access VPN access to managed and unmanaged clients. Each Mobile Access gateway leads to its own user portal, reached from a browser on any computer at the default /sslvpn path [18] (**Confirmed**). That portal was the door. CPR says the attackers came in through unpatched Mobile Access portals in exploitation "consistent with PHP2Shell", roughly one week after a security fix became available [5] (**Confirmed**). The report gives no support-article number or date for that fix [5] (**Confirmed**). CSIRT Italia's alert of 9 November lists Firewall and Security Gateway R81.20 to R82.20, end-of-support R80 to R81.10 and Spark as affected, names the Mobile Access Portal among affected features, marks exploitation present and references sk1000302 [9] (**Confirmed**).

The gateways kept evidence. CPR found PHP session artifacts created in the portal's temporary directory on 30 October carrying a marker associated with the exploitation, and hundreds of segmentation faults in the portal's Apache and PHP workers in the same window [5] (**Confirmed**). Evidence suggested some compromises succeeded [5] (**Confirmed**).

## Escalation: CVE-2026-123039

After initial access the attacker was the portal's service account. CVE-2026-123039 in the DynamicCLI IPC interface took it to root [5] (**Confirmed**). The CPR report links sk1000362 for this step [5] (**Confirmed**).

## Persistence on the portal: web shells

With root, the attackers placed PHP web shells, multiple files with a "zz" prefix and a ".tpl" suffix, in the template directory the Mobile Access portal uses to build its login pages [5] (**Confirmed**). A small command shell was later replaced by a fuller one behind a hard-coded key that supports OS commands, PHP code execution and file upload [5] (**Confirmed**). The shells' contents and key are not reproduced here.

## TSGA: the gateway implant

TSGA was first run from a temporary path under the name CPconfigdaemon. Run as root, it relocates to "the boot persistence directory" and relaunches as slot_CPconfigdaemon [5] (**Confirmed**). Both names resemble a Check Point process name (**Inferred**). It listens on TCP 11072 on all IPv4 interfaces and also uses a Unix socket [5] (**Confirmed**). CPR calls it a Linux gateway implant with substantial Check Point-specific functionality: encrypted remote access, configuration theft, backup and snapshot persistence, process injection and binary firewall-log tampering [5] (**Confirmed**). CPR does not name the boot directory, the processes it injects into or how attacker connections are marked [5] (**Confirmed**).

## TSProxy: the in-process proxy

TSProxy is a shared library embedded in TSGA and dropped as /lib/libcpfwcommon.so, a name that blends with Check Point's own libraries (**Inferred**). It is injected into selected appliance processes, where it intercepts networking functions. Specially marked attacker connections are handled by the implant while ordinary traffic continues, and it supports encrypted SOCKS-style proxying [5] (**Confirmed**). In practice the attacker's traffic can ride inside a legitimate appliance process (**Inferred** from [5]).

## Discovery: gogo

The attackers ran the gogo scanner on the gateway to find internal assets and services [5] (**Confirmed**). CPR cites CISA's AA25-022A for gogo's earlier use in Ivanti exploitation. That advisory covers chained Ivanti Cloud Service Appliance flaws and the actors' use of the Obelisk and GoGo scanners, and attributes the activity to no country [34] (**Confirmed**). The "China-nexus" reading of gogo comes from CPR, not from CISA [5] [34] (**Confirmed**).

## Lateral movement: the hop to ESXi

The attacker moved from the gateway to a VMware ESXi host over SSH, authenticating as vpxuser [5] (**Confirmed**). How the credential was obtained is not stated [5] (**Confirmed**). The Mandiant post CPR cites for vpxuser explains what the account is: vCenter creates it as a privileged account on each ESXi host when the host first connects, stores its password encrypted in the vCenter database, and rotates it every 30 days by default. In that 2023 case, UNC3886 harvested and cracked vpxuser credentials after rooting vCenter [33] (**Confirmed**). vpxuser is valuable because vCenter, not the host administrator, manages it (**Inferred** from [33]).

## Impact: the destroy_v6 wiper

The destroy_v6 Linux ELF wiper was staged and run on the ESXi host [5] (**Confirmed**). It deletes files recursively regardless of extension, can exclude chosen subtrees, overwrites with zeros before deleting by default and skips the overwrite in a fast mode. It writes a note file, DREAM_ANNEXATION.txt, into each directory it processes [5] (**Confirmed**). No encryption is described [5] (**Confirmed**). CPR's indicator table spells the file name "destory_v6" [5] (**Confirmed**).

The note is politically themed and timestamped, explicitly rejects ransom negotiation and uses the Dream Security brand. CPR's attribution section says it is in Hebrew and refers to the Israeli-Palestinian conflict [5] (**Confirmed**). Security Affairs reports the same [46] (**Reported**). The note's text is not reproduced here.

Destructive activity is reported for the first wave only; for the second wave on 2 November CPR found no evidence of destructive activity [5] (**Confirmed**). Neither wave showed a clear sector preference, which CPR reads as opportunistic initial-access attempts [5] (**Confirmed**).

## Indicators at advisory level

These are the values CPR publishes [5] (**Confirmed**; each hash was compared with the report on 13 November 2026). They are listed for matching, not for retrieval.

| Label in the report | SHA-256 |
|---|---|
| .tpl web shell | edb3e92eb7bda7413a09edcc4b1ba3cbed4bcdf42808a8abce63b6e4c3fda2b3 |

| Label in the report | SHA-256 |
|---|---|
| slot_CPconfigdaemon (TSGA, relocated) | 4171b521fa6441382aa2fa014a08e18ff9a6e0ab6096c9144072bf46b37a2ec8 |
| CPconfigdaemon (TSGA, first run) | d7549671c7189979f0624ec52dad9ea6a707d23146e3585ab8f8c4720eca0c63 |
| gogo | 3b51080a909023f7d484e2443740b572307ce0054eb9e32d98f0a06bfcd2db90 |
| destory_v6 (the destroy_v6 wiper) | c7d9477309fac6c638a1128442056a242de086996add8cb49cd6496c36003237 |
| DREAM_ANNEXATION.txt | 0522937c0c0337be54fe25493539e5f5f8ceb9742c980aaff1cfc9515f3a96f7 |
| philistine (PhiliKit, for lineage) | ee16e1695711b9d60c62925fcfb2fe1a29c18ae26565bc05410a14e16d2a39d7 |
| libdssafe.so (PhiliKit networking component, for lineage) | fb1a6235eb6bce8c9ec8cd8bb85f17c9c2bde8ecb45b7a243a30ceadf26654da |

Network: 130.94.19[.]204 and 130.94.19[.]168, on LightNode VPS infrastructure. Host artifacts named in the report: /lib/libcpfwcommon.so, a listener on TCP 11072, and "zz"-prefixed .tpl files in the portal's login template directory [5] (**Confirmed**).

# Part 4: attribution

## The tooling lineage

CPR says TSGA and TSProxy are modified variants of PhiliKit and share distinctive code, configuration and cryptographic material with it [5] (**Confirmed**). PhiliKit is a passive backdoor and installer aimed at Ivanti VPN appliances, first reported after a sample named "philistine" was uploaded to VirusTotal on 25 February 2026 [5] (**Confirmed**). The evidence CPR gives is specific:

- TSGA and the PhiliKit implant both descend from Tiny SHell and use authenticated, encrypted communications over a fixed TCP port and a Unix socket. The analysed PhiliKit build listens on loopback only; TSGA listens on all IPv4 interfaces [5] (**Confirmed**).
- TSProxy and libdssafe.so, PhiliKit's networking component, share identical operator credentials, transport secrets, three activation-selector digests and the same TLS certificate and private key. CPR says this strongly supports a shared tooling lineage [5] (**Confirmed**).

A shared private key is hard to explain by coincidence (**Inferred**). It ties the tools together. It does not by itself tie the operators together, because tooling can be shared, sold or stolen (**Inferred**).

## What ESET says

ESET's APT Activity Report for October 2025 to March 2026, published 28 May 2026, describes PhiliKit as a new implant it assesses to be part of UNC5221's SPAWN toolset targeting Ivanti VPN appliances [12] [13] (**Confirmed**). ESET found the sample after a VirusTotal upload from South Korea on 25 February 2026 and says it was possibly used with CVE-2026-1281 and CVE-2026-1340 [13] (**Confirmed**). KEV lists both of those CVEs as Ivanti EPMM code injection flaws, not VPN flaws [7] (**Confirmed**); the library's home for them is the Ivanti EPMM study. The report does not use the name "Armory Castle" [12] (**Confirmed**).

## The China-nexus pointers

CPR points toward China-nexus activity on three grounds [5] (**Confirmed**):

- PhiliKit's association with UNC5221, through ESET.
- gogo's reported use by China-nexus actors exploiting Ivanti, citing AA25-022A, which itself names no country [34].
- Attacker infrastructure on LightNode VPS, previously associated with China-nexus activity.

Scanning was concentrated between 00:00 and 09:00 UTC, which is 08:00 to 17:00 China time, broadly Chinese working hours [5] (**Confirmed**).

The library's ATT&CK data holds no group record for UNC5221 by id or alias. UNC5221 appears only in the descriptions of campaign C0029 Cutting Edge and of the software S9011 BRUSHFIRE, S9012 TRAILBLAZE, S9013 DRYHOOK, S9014 PHASEJAM, S9015 BRICKSTORM and S9024 SPAWNCHIMERA [47] (**Confirmed**). Those pages are context for UNC5221's earlier edge-device record, not objects of this campaign. The library's BeyondTrust study records that Google names ARMORY CASTLE as the actor formerly tracked as UNC5221 [50] (**Reported**). The Ivanti lineage is covered in Ivanti Connect Secure 2026 and the wider picture in Threat Actors: China.

## What does not fully align

CPR names three attributes that do not appear to fully align with known China-nexus groups, UNC5221 specifically [5] (**Confirmed**):

- The operation was destructive.
- The first wave focused on Israel, and the note is in Hebrew and refers to the Israeli-Palestinian conflict.
- The PhiliKit name derives from the internal sample name "philistine".

SecurityWeek reports Check Point saying the wiper does not align with known Chinese operations [43] (**Reported**).

## Check Point's conclusion

Check Point states that the evidence does not allow a high-confidence assessment of the operation. It lists plausible scenarios: the identified actor ran the whole campaign; it acted only as an initial access broker; or it took part in a false flag. The destruction may have been a smoke screen [5] (**Confirmed**).

There is one more thread. Dream had recently published research on PHP2Shell exploitation of Palo Alto Networks devices by China-nexus actors. CPR says the timing raises the possibility of retaliation, but the evidence does not establish a motive [5] (**Confirmed**). Dream's report, dated 26 October and updated 29

October, describes 25 rooted PAN-OS servers in the United States, Japan, Taiwan and South Korea, three of them in a US government-affiliated environment. It says Unit 42 tracks the activity as CL-UNK-1280 with a Chinese-speaking operator in UTC+8, and names no actor [31] (**Reported**). Help Net Security reports that Palo Alto Networks and Dream later confirmed the firewalls were Palo Alto Networks devices, and that about 0.02% of the installed base had internet-facing management interfaces [32] (**Reported**). Read together, a wiper note branded with the name of the firm that had just exposed China-nexus PHP2Shell activity could be a message, a misdirection or something else; the record does not say (**Inferred**).

### Where the press goes further

The Hacker News writes that ESET first documented PhiliKit in June 2026 and attributed it to a China-nexus group tracked as Armory Castle (formerly UNC5221) [44] (**Reported**). ESET's report is dated 28 May and uses UNC5221 [12] (**Confirmed**). No ESET publication using "Armory Castle" was found [12] (**Confirmed** for the report opened). The Hacker News' own 29 October article, about Warp Panda, lists it as also tracked as Armory Castle (formerly UNC5221), Clay Typhoon and VerdantBamboo, without a vendor source for the names [45] (**Reported**). This study keeps to CPR's and ESET's wording.

## Part 5: the platform and the 2026 frame

### Check Point's exploited-flaw record

BleepingComputer reports that CISA has added five Check Point flaws to KEV over the past two years [42] (**Reported**). The KEV catalog confirms five at that point: CVE-2024-24919, CVE-2026-50751, CVE-2026-16232, CVE-2026-85102 and CVE-2026-93616; CVE-2026-123039 became the sixth on 13 November 2026 [7] (**Confirmed**).

| CVE | Surface | Weakness and score | KEV | Sources |
|---|---|---|---|---|
| CVE-2024-24919 | Information disclosure in Quantum Gateway, CloudGuard Network and Spark with Remote Access IPsec VPN or Mobile Access. First attempts traced to 7 Apr 2024; fixed in R81.20 Take 65, R81.10 Take 150 and R81 Take 99 | CWE-200, CVSS 3.1 8.6 | 30 May 2024, ransomware Known | [23] [24] |
| CVE-2026-50751 | Remote Access and Mobile Access IKEv1 certificate validation bypass, Quantum Security Gateway and Spark | CWE-287, CVSS 4.0 9.3 | 8 Jun 2026, ransomware Known | [26] [7] |
| CVE-2026-16232 | SmartConsole login authentication bypass, Security Management and MDSM; exploited against a very small number of customers | CWE-287, CVSS 4.0 9.3 | 22 Jul 2026 | [25] |
| CVE-2026-85102 | Improper certificate-data validation in Security Gateway VPN negotiation, pre-auth RCE; attack waves from 12 Sep 2026 including Spark customers | CWE-295, CVSS 9.8 | 22 Sep 2026 | [11] [27] [29] [7] |
| CVE-2026-93616 | Path traversal in the Management web service; pinpointed zero-day attacks from 23 Jul 2026 | CWE-22, CVSS 9.8 | 22 Sep 2026 | [27] [29] [7] |
| CVE-2026-85103 | Heap overflow in VPN certificate ASN.1 decoding, also affects Security Management | CVSS 9.8 (CERT-EU) | Not in the catalog version read | [11] [7] |

| CVE | Surface | Weakness and score | KEV | Sources |
|---|---|---|---|---|
| CVE-2026-91843 | Stack overflow in the login process of Security Management and Log Servers (sk1000155); no exploitation statement | not checked | Not listed | [28] |
| CVE-2026-107484 | Gaia Portal backend handlers, authenticated privilege escalation (sk1000291); no exploitation statement | CWE-269 | Not listed | [8] [6] |
| CVE-2026-123039 | Gaia DynamicCLI local privilege escalation to root | CWE-862, CWE-732, CVSS 3.1 7.8 | 13 Nov 2026, due 16 Nov | [1] [7] |

CERT-EU 2026-012 pairs CVE-2026-85102 with CVE-2026-85103, but the exploited and KEV-listed September pair is CVE-2026-85102 with CVE-2026-93616. The two pairs should not be merged [7] [11] [29] (**Confirmed**). The CVE-2026-50751 story is told in full in its home study: first exploitation traced to 7 May 2026, a fix on 8 June, and a same-day KEV entry with ransomware use Known [26] [51] [7] (**Confirmed**).

Three of the earlier five KEV entries are on the gateway's remote-access path (CVE-2024-24919, CVE-2026-50751, CVE-2026-85102) and two are on the management plane (CVE-2026-16232, CVE-2026-93616). The sixth, CVE-2026-123039, adds root on the box that sits behind an exposed Mobile Access portal (**Inferred** from [7]).

## End of support is a security state

Check Point's support periods for Security Gateway and Management are: R81 until October 2024, R81.10 until March 2026, R81.20 until May 2027, R82 until April 2029, R82.10 until June 2030 and R82.20 until September 2030. Support usually ends four years after release [20] [21] (**Confirmed**). The CVE-2026-93616 record already labels R81.10, R81 and R80.x as "(EOS)" [30] (**Confirmed**).

CVE-2026-50751 still got an R81.10 fix (Take 187) in June 2026, three months after R81.10's end of support [51] [20] (**Confirmed**). CVE-2024-24919 got R81.10 Take 150 and R81 Take 99 in May 2024, while both were still supported [23] [20] (**Confirmed**). CVE-2026-123039 gets none on those branches [3] (**Confirmed**). For R81 and R81.10 the vendor routes are the interim service stop or an upgrade to a supported release (**Inferred** from [3] [21]).

### The 2026 edge pattern

| Product | CVE(s) | KEV added | Library study |
|---|---|---|---|
| Fortinet FortiCloud SSO | CVE-2026-24858 | 27 Jan 2026 | FortiCloud SSO |
| Ivanti EPMM | CVE-2026-1281; CVE-2026-1340 | 29 Jan 2026; 8 Apr 2026 | Ivanti EPMM |
| Palo Alto Networks PAN-OS | CVE-2026-0257 | 29 May 2026 | PAN-OS CVE-2026-0257 |
| Check Point Remote Access VPN | CVE-2026-50751 | 8 Jun 2026 | Check Point VPN IKEv1 |
| N-able N-central | CVE-2026-18577; CVE-2026-18556; CVE-2026-86218 | 3 Aug; 4 Aug; 8 Sep 2026 | N-able N-central |
| Citrix NetScaler | CVE-2026-88771, CVE-2026-88772; CVE-2026-88779 | 27 Sep; 4 Oct 2026 | Citrix NetScaler September 2026 |
| Ivanti Connect Secure | CVE-2026-104935; CVE-2026-111357, CVE-2026-118527 | 13 Oct; 30 Oct 2026 | Ivanti Connect Secure 2026 |
| PHP2Shell (on PAN-OS and Check Point) | CVE-2026-109618, CVE-2026-109619 | 26 Oct 2026 | PHP2Shell October 2026 |
| Check Point Gaia | CVE-2026-123039 | 13 Nov 2026 | this study |

KEV dates come from the catalog [7] (**Confirmed**). In each row the first hop is an internet-facing appliance with its own Linux userland and its own web or management stack. Where a root step is described, it is a local flaw in the appliance's own plumbing: Fragnesia on PAN-OS, CVE-2026-111357 on Ivanti Connect Secure, DynamicCLI on Gaia. These are platforms where EDR coverage is usually absent (**Inferred** from [5] [7] [31]).

### ESXi as the second target

Destruction aimed at ESXi is not new. CISA's AA23-039A reported in February 2023 that ESXiArgs ransomware encrypted configuration files on more than 3,800 ESXi servers worldwide, and advised updating, disabling SLP and keeping ESXi off the public internet [35] (**Confirmed**). In 2026 the logging on ESX itself became a target: VMware ESX CVE-2026-41709 (VMSA-2026-0006, published 29 July, revised 19 August, CVSS 2.7) lets a malicious administrator perform certain operations without being logged, and CISA added it to KEV on 28 October with an 11 November due date [7] [36] (**Confirmed**). Help Net Security reports CrowdStrike's finding that the China-nexus group Warp Panda used it as a zero-day to reduce audit visibility on ESX [32] (**Reported**). The Hacker News' 29 October article says Warp Panda is also tracked as Armory Castle (formerly UNC5221), Clay Typhoon and VerdantBamboo, without naming the vendor behind those names [45] (**Reported**). UNC5221 is the group ESET ties to PhiliKit. No primary source opened here makes that equation, and none ties Warp Panda or CVE-2026-41709 to this campaign.

What is new in this campaign is the route: not an exposed ESXi service, but a firewall that could reach the hypervisor over SSH with a vCenter-managed credential [5] [33] (**Confirmed** facts; the contrast **Inferred**).

# Part 6: the vulnerability-management view

**KEV lag.** CVE-2026-123039 was not in KEV catalog version 2026.11.10, released on 10 November, two days before the CVE existed publicly [7] (**Confirmed**). CISA added it in catalog version 2026.11.13, one day after publication, with a 16 November due date under BOD 26-04 [7] (**Confirmed**). The vendor said it was exploited and the Canadian Centre repeated it on 12 November [3] [6] (**Confirmed**). A patch queue driven only by KEV would have surfaced it one day after the vendor did, and the three-day due date shows how little room that day leaves (**Inferred**).

**The score.** The CNA scored it 7.8 with a local attack vector [1] (**Confirmed**). That is consistent with the vendor's prerequisite of prior local code execution [3] (**Inferred**). In this chain PHP2Shell supplied that execution remotely, so the score understates real-world severity on any gateway with an exposed Mobile Access portal (**Inferred** from [1] [3] [5]). Treat the pair as one remote root chain when prioritizing (**Inferred**).

**The ranges.** The CVE record and sk1000362 disagree on version ceilings and on whether R81 and R81.10 are affected [1] [3] (**Confirmed**). NVD carried no CPE configuration on 13 November [2] (**Confirmed**), so scanner coverage depends on each scanner's own reading (**Inferred**). Use the support article (**Inferred**).

**The scope.** Management and Log Servers, Multi-Domain servers and Maestro Orchestrators are affected as well as firewalls [3] (**Confirmed**). An inventory limited to internet-facing gateways misses part of the fix list (**Inferred**).

**Two Gaia flaws, one day.** CVE-2026-107484 arrived one minute earlier with its own article [6] [8] (**Confirmed**). Patch both.

**The federal frame.** The KEV entries for the PHP2Shell pair cite BOD 26-04, Prioritizing Security Updates Based on Risk, and CISA's Forensics Triage Requirements implementation guidance [7] (**Confirmed**). BOD 23-02 already requires federal civilian agencies to take internet-exposed management interfaces of firewalls, VPN concentrators and similar devices off the internet, or put them behind zero-trust access with a separate policy enforcement point, within 14 days of discovery; it binds only those agencies [38] (**Confirmed**). The Mobile Access portal is a user portal, not a management interface, so BOD 23-02 does not reach it (**Inferred** from [18] [38]).

# Part 7: the defender view

## Patch, and know what the mitigation costs

The fix is the Jumbo Hotfix Take in sk1000362 [3] (**Confirmed**). Where patching must wait, the support article's temporary mitigation, described functionally, is to stop the dynamic_server process through the Gaia configuration database so it does not restart, and to save that configuration. Reversing it means re-enabling the same setting and saving. The article also explains how to check whether the process is running [3] (**Confirmed**). The cost: while the process is stopped, the Dynamic CLI commands of sk144112 fail [3] (**Confirmed**). Which commands those are was not checked, because the sk144112 body needs a login [4].

## Verify the fix

After the fix, the control socket is owned by root with the config group, mode 0660, and is no longer world-writable [3] (**Confirmed**). The fixed daemon blocks and logs unauthenticated calls, recording the rejected caller's uid and pid. A rejection from an unexpected uid, such as a low-privilege service account, means an escalation attempt was made and blocked. Check Point advises correlating bursts of rejections with portal, web and authentication logs to find the source [3] (**Confirmed**).

## Hunt in the DynamicCLI log

The vulnerable daemon records every command it receives in its own log, dynamicCli.log under /var/log [3] (**Confirmed**). Legitimate requests carry a fixed Clish wrapper, so a logged command without it may mean root execution through the socket [3] (**Confirmed**). sk1000362 also points defenders at an execution path that legitimate traffic rarely uses, and at classes of command tied to exploitation: identity and credential-file checks, network utilities, downloaders, encoding, account creation and SSH authorized-key changes [3] (**Confirmed**). Run the hunt on every Force Firewall and every cluster member [3] (**Confirmed**). The exact strings are in the support article and are not repeated here.

## Hunt for the campaign

- **Initial access.** PHP session artifacts with the exploitation marker in the portal's temporary directory, and bursts of Apache and PHP worker segmentation faults [5] (**Confirmed**).
- **Web shells.** "zz"-prefixed .tpl files in the portal's login template directory [5] (**Confirmed**).
- **TSGA and TSProxy.** The process names CPconfigdaemon and slot_CPconfigdaemon, the library /lib/libcpfwcommon.so, a listener on TCP 11072 and the hashes in Part 3 [5] (**Confirmed**).
- **Network.** 130.94.19[.]204 and 130.94.19[.]168 [5] (**Confirmed**).
- **From the gateway.** Internal scanning and outbound SSH that originate on the gateway itself, especially toward ESXi [5] (**Confirmed** behavior; the hunt **Inferred**).
- **On ESXi.** SSH logons as vpxuser that did not come from vCenter, and the destroy_v6 and DREAM_ANNEXATION.txt hashes [5] [33] (**Inferred**).

No rule in the SigmaHQ repository covers this campaign. The SigmaHQ repository's main tree on 13 November 2026 (a tree of 6,727 entries, last commit 08:54 UTC) has no path matching Check Point, DynamicCLI, PHP2Shell, gogo or an ESXi wiper [41] (**Confirmed**). Gaia appliances typically run without the organization's EDR agent, so detection depends on the vendor's own logs, off-box log forwarding and netflow from the gateway (**Inferred**; no primary on EDR support for Gaia was opened).

## Recover without restoring the implant

CPR's report has no recommendations or recovery section and names no ATT&CK technique ids [5] (**Confirmed**). The recovery lesson has to be drawn from what TSGA does. Because it has backup and snapshot persistence, a Gaia backup or snapshot taken after compromise can bring it back on restore. Because it tampers with binary firewall logs, on-box logs are not trustworthy [5] (**Confirmed** capabilities; the lesson **Inferred**). Recovery therefore means a clean image of a fixed release, a known-good configuration, rotated administrator and service credentials and certificates, re-issued VPN trust and restored off-box logging (**Inferred** from [5] [40]).

## Close the path to the hypervisor

ESXi SSH (Remote Tech Support Mode) is a troubleshooting service, disabled by default, that works independently of lockdown mode. Lockdown mode forces operations through vCenter Server. Normal lockdown keeps the DCUI for exception users and strict lockdown stops it. Exception users should be service accounts, not administrators [37] (**Confirmed**). For this campaign that means: ESXi SSH off unless needed, lockdown mode on, ESXi management on a network the gateway cannot reach, no SSH path from any appliance to any hypervisor, a review of the vpxuser trust, and offline or immutable backups the hypervisor cannot delete (**Inferred** from [5] [33] [37]).

## Shrink the surface

The entry point was internet-facing Mobile Access portals [5] (**Confirmed**). Limit or disable portal exposure where it is unused, restrict it by geography or source, control egress from the gateway itself, and monitor SSH and internal scanning that originate from the gateway (**Inferred**).

The edge-device guidance of February 2025 frames the rest. CISA announced it on 4 February 2025 with ASD's ACSC, the Canadian Centre, NCSC-UK and partners: the Canadian Centre led Security Considerations for Edge Devices, ASD's ACSC led the executive and practitioner Mitigation Strategies, and NCSC-UK led the forensic and monitoring specifications for manufacturers [39] (**Confirmed**). ITSM.80.101 recommends patching quickly after testing; inventorying edge devices and replacing them before end of life, with compensating controls in the meantime; never exposing network management interfaces to the internet; forwarding detailed logs off the device and alerting on admin logons and configuration changes; phishing-resistant MFA for administrators; disabling unused features; and planning and exercising for edge-device compromise [40] (**Confirmed**). Most items on that list map to a step in this campaign: patching speed, end of life, off-device logs and disabling unused features such as an unneeded portal (**Inferred**).

## Incident response checklist

Assembled from the primaries, with no commands (**Inferred** as an assembly; each component cited):

1. Apply sk1000362 and sk1000291 [3] [6]. Upgrade R81 and R81.10 [3] [20].
2. If patching must wait, apply the interim mitigation and accept the Dynamic CLI loss [3].
3. Verify the socket's ownership and mode after patching and watch for rejection entries [3].
4. Review the DynamicCLI log as sk1000362 describes, on every gateway and cluster member [3].
5. Sweep for CPR's file names, hashes, template-directory web shells, the TCP 11072 listener and the two addresses [5].
6. If anything is found: isolate the device; preserve off-box logs; rebuild from a clean image rather than a post-compromise backup or snapshot; rotate credentials and certificates; re-issue VPN trust; check every ESXi host the gateway could reach; engage Check Point TAC [5] [40].

## What is overstated and what is understated

- **Overstated: the zero-day-gives-root headline.** The flaw is local (AV:L, PR:L) and needs prior code execution [1] [3] (**Confirmed**). It mattered because PHP2Shell first gave that execution on Mobile Access portals left unpatched about a week after a fix [5] (**Confirmed**). The headline is accurate about exploitation before disclosure and misleading about reach (**Inferred**).
- **Overstated: a firm China attribution.** CPR declines a high-confidence call and lists four scenarios [5] (**Confirmed**). "Armory Castle" appears in news reports and in Google's naming recorded in the library [50], not in ESET's report or CPR's [12] [44] [45] (**Confirmed** for the absence; the name **Reported**). CPR's gloss of AA25-022A as about "Chinese-nexus" actors goes beyond CISA's text, which names no country [34] (**Confirmed**).
- **Understated: the 7.8 score.** In this chain the local precondition was supplied remotely (**Inferred** from [1] [3] [5]).
- **Understated: the KEV gap.** Exploited, vendor-confirmed and absent from the catalog version current on 13 November [3] [7] (**Confirmed**).
- **Understated: the fleet problem.** R81 and R81.10 are past end of support and have no fixed Take [3] [20] (**Confirmed**).
- **Understated: the hypervisor hop.** One gateway with SSH reach to ESXi and a vpxuser credential turned an edge compromise into destruction [5] (**Confirmed** facts; the weighting **Inferred**).
- **Understated: the non-destructive wave.** The 2 November wave was global and showed no destruction, but TSGA's backup and snapshot persistence means a quiet compromise can outlive a restore [5] (**Inferred** from **Confirmed** capabilities).

## MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names, tactics, CAPEC links and D3FEND links come from the library's `data/attack/technique_profiles.jsonl`, `technique_releases.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files [47] [48] (**Confirmed**). The CPR report lists no ATT&CK ids, so every binding below is this study's own mapping [5] (**Confirmed**). No ATT&CK for ICS table applies: no source describes an industrial victim or effect.

### Groups, software and campaigns

No group, software or campaign object is bound. The library's ATT&CK data has no group record for UNC5221 by id or alias, and no software id for PhiliKit, TSGA, TSProxy, gogo or destroy_v6 [47] (**Confirmed**). The UNC5221 context pages are linked in Part 4 as context only: C0029 Cutting Edge, S9011 BRUSHFIRE, S9012 TRAILBLAZE, S9013 DRYHOOK, S9014 PHASEJAM, S9015 BRICKSTORM and S9024 SPAWNCHIMERA [47] (**Confirmed**).

## ATT&CK Enterprise techniques

| ID | Name | Tactic | Dated event or report | Sources |
|---|---|---|---|---|
| T1595.002 | Vulnerability Scanning | Reconnaissance | Scanning for unpatched Mobile Access portals in the 30 Oct and 2 Nov 2026 waves, concentrated 00:00 to 09:00 UTC (CPR, 12 Nov) | [5] |
| T1583.003 | Virtual Private Server | Resource Development | Attacker addresses on LightNode VPS (CPR, 12 Nov) | [5] |
| T1190 | Exploit Public-Facing Application | Initial Access | PHP2Shell against Mobile Access portals from 30 Oct 2026 (CPR; KEV, 26 Oct) | [5] [7] |
| T1133 | External Remote Services | Initial Access | The Mobile Access remote access portal was the entry; the record describes exploiting it, not using a session (**Inferred**, lower score) | [5] [18] |
| T1059.004 | Unix Shell | Execution | Web shell command execution and TSGA remote access on the Gaia gateway (CPR, 12 Nov) | [5] |
| T1068 | Exploitation for Privilege Escalation | Privilege Escalation | CVE-2026-123039 from the portal service account to root in the campaign that began 30 Oct 2026; CPR does not date this step (CVE record and sk1000362, 12 Nov; CPR) | [1] [3] [5] |
| T1505.003 | Web Shell | Persistence | PHP web shells in the portal's login template directory (CPR, 12 Nov) | [5] |
| T1037 | Boot or Logon Initialization Scripts | Persistence | TSGA relocates to the boot persistence directory; mechanism unstated, so parent only (**Inferred**, lower score) | [5] |
| T1055 | Process Injection | Stealth | TSProxy loaded into selected appliance processes; TSGA process injection (CPR, 12 Nov) | [5] |
| T1036.005 | Match Legitimate Resource Name or Location | Stealth | TSGA runs as CPconfigdaemon and slot_CPconfigdaemon, names resembling a Check Point process (CPR, 12 Nov; resemblance and sub-technique choice **Inferred**) | [5] |
| T1070 | Indicator Removal | Stealth | TSGA binary firewall-log tampering (CPR, 12 Nov) | [5] |
| T1046 | Network Service Discovery | Discovery | gogo run on the gateway to find internal assets and services (CPR, 12 Nov) | [5] |
| T1021.004 | SSH | Lateral Movement | Gateway to VMware ESXi host over SSH, first wave, 30 Oct 2026 | [5] |
| T1078 | Valid Accounts | Stealth | SSH logon as the vCenter-managed vpxuser account; credential origin unstated (**Inferred**, lower score) | [5] [33] |
| T1005 | Data from Local System | Collection | TSGA theft of appliance configurations (CPR, 12 Nov) | [5] |
| T1573 | Encrypted Channel | Command and Control | TSGA encrypted remote access; TSProxy encrypted proxying (CPR, 12 Nov) | [5] |
| T1090 | Proxy | Command and Control | TSProxy SOCKS-style proxying inside appliance processes (CPR, 12 Nov) | [5] |
| T1105 | Ingress Tool Transfer | Command and Control | Web shell file upload; gogo deployed on the gateway; destroy_v6 staged on ESXi (CPR, 12 Nov) | [5] |

| ID | Name | Tactic | Dated event or report | Sources |
|---|---|---|---|---|
| T1485 | Data Destruction | Impact | destroy_v6 overwrote and deleted files on ESXi, 30 Oct 2026 | [5] |
| T1491.001 | Internal Defacement | Impact | Political note DREAM_ANNEXATION.txt written to each processed directory, 30 Oct 2026 (defacement mapping **Inferred**, lower score) | [5] |

All 20 ids are live in ATT&CK v20.0 in the library's `technique_releases.jsonl` and have generated pages [47] (**Confirmed**). T1055 is bound under Stealth, its v20 defense tactic, and T1078 under Stealth because initial access and persistence do not describe this use [47] (**Confirmed** tactics; the choice **Inferred**).

Considered and not bound (**Inferred**): T1036.011 Overwrite Process Arguments and T1036.004 Masquerade Task or Service, because the method is not stated; T1037.004 RC Scripts, because the boot mechanism is not named; T1602 Data from Configuration Repository, whose scope is management-protocol repositories; T1095 Non-Application Layer Protocol, because the protocol is not described; T1543, T1574.006, T1529 and T1486, for lack of a stated behavior. The defense-impairment ids T1685.004 and T1685.006 are not bound, because firewall logs are neither of those log types and the record does not say logs were cleared or logging disabled. T1562 was revoked in ATT&CK 19.0 and maps to T1685 in `superseded_by.jsonl`, and T1070.002 maps to T1685.006; neither is used here [47] (**Confirmed**).

## CWE and CAPEC

| CWE | Name | Where it is assigned | Sources |
|---|---|---|---|
| CWE-862 | Missing Authorization | CVE-2026-123039 (CNA; NVD) | [1] [2] |
| CWE-732 | Incorrect Permission Assignment for Critical Resource | CVE-2026-123039 (CNA; NVD) | [1] [2] |
| CWE-269 | Improper Privilege Management | CVE-2026-107484, the same-day Gaia Portal sibling | [8] |
| CWE-416, CWE-755, CWE-824, CWE-1325, CWE-1419 | Use After Free; Improper Handling of Exceptional Conditions; Access of Uninitialized Pointer; Improperly Controlled Sequential Memory Allocation; Incorrect Initialization of Resource | PHP2Shell, CVE-2026-109618 and CVE-2026-109619 (KEV; library) | [7] [49] |

The library has rows for these in the CWE Reference and no per-id CWE pages [49] (**Confirmed**).

| CAPEC | Name | Via | Where it meets the record |
|---|---|---|---|
| CAPEC-1 | Accessing Functionality Not Properly Constrained by ACLs | CWE-732 | A root service reachable by any local user through a world-writable socket [1] (**Inferred** fit) |
| CAPEC-180 | Exploiting Incorrectly Configured Access Control Security Levels | CWE-732 | The socket's permissions were set too broadly [1] [3] (**Inferred** fit) |
| CAPEC-122 | Privilege Abuse | CWE-732 | The portal service account used the socket to act as root [5] (**Inferred** fit) |
| CAPEC-234 | Hijacking a privileged process | CWE-732 | The root daemon ran whatever it was sent [3] (**Inferred** fit) |

| CAPEC | Name | Via | Where it meets the record |
|---|---|---|---|
| CAPEC-650 | Upload a Web Shell to a Web Server | T1505.003 | Web shells in the portal's login templates [5] |
| CAPEC-268 | Audit Log Manipulation | T1070 | TSGA binary firewall-log tampering [5] |
| CAPEC-300 | Port Scanning | T1046 | gogo internal discovery [5] |
| CAPEC-545 | Pull Data from System Resources | T1005 | TSGA configuration theft [5] |
| CAPEC-130 | Excessive Allocation | CWE-1325 | The PHP2Shell memory-pressure flaw, the chain's first step [49] |

The library relates CWE-862 to one CAPEC entry only, CAPEC-665 Exploitation of Thunderbolt Protection Flaws, which does not fit a local socket [48] (**Confirmed** relation; the fit **Inferred**). It relates CWE-732 to seven further entries (CAPEC-17, 60, 61, 62, 127, 206 and 642) that do not meet this record [48] (**Confirmed**). Other CAPEC entries the library ties to bound techniques fit weakly and are left out: CAPEC-564 (T1037), CAPEC-560 (T1078), CAPEC-555 (T1133), CAPEC-251 and CAPEC-660 (T1055) and CAPEC-543 and CAPEC-616 (T1036.005) [47] (**Confirmed**). No source assigns a CAPEC id. See the CAPEC Reference.

## D3FEND countermeasures

| D3FEND countermeasure | Techniques the library maps it to (from this study) | Where it meets the record |
|---|---|---|
| Local File Permissions | T1505.003, T1036.005, T1005 | The fix itself: the socket restricted to root and the config group [3] (**Inferred** fit) |
| File Integrity Monitoring | T1505.003, T1036.005, T1005 | New .tpl files in the template directory; a new library under /lib; TSGA's relocated binary [5] (**Inferred** fit) |
| Process Spawn Analysis | T1505.003 | Shells spawned by the portal's web workers [5] (**Inferred** fit) |
| Process Lineage Analysis | T1505.003 | Root commands whose parent is the DynamicCLI daemon rather than Clish [3] (**Inferred** fit) |
| Inbound Traffic Filtering | T1190 | Restricting Mobile Access portal exposure by source [5] (**Inferred** fit) |
| Network Traffic Signature Analysis | T1190, T1021.004, T1573, T1105 | Matching PHP2Shell exploitation and the two attacker addresses [5] (**Inferred** fit) |
| Remote Terminal Session Detection | T1190, T1021.004, T1573, T1105 | SSH sessions from the gateway to ESXi [5] (**Inferred** fit) |
| Network Traffic Filtering | T1190, T1021.004, T1573, T1105 | No SSH path from appliance to hypervisor [5] [37] (**Inferred** fit) |
| Session Termination | T1133, T1021.004 | Ending gateway-originated SSH sessions found in the hunt (**Inferred** fit) |
| Outbound Traffic Filtering | T1573, T1105 | Egress control on the gateway itself [5] (**Inferred** fit) |
| Relay Pattern Analysis | T1573, T1105 | TSProxy relaying attacker traffic through appliance processes [5] (**Inferred** fit) |
| User Account Permissions | T1078 | Lockdown mode and service-account-only exceptions on ESXi [37] (**Inferred** fit) |

The library's D3FEND mappings for T1068 are memory-corruption hardening (Memory Boundary Tracking, Process Code Segment Verification, Process Segment Execution Prevention, Segment Address Offset Randomization, Shadow Stack Comparisons and Stack Frame Canary Validation). None of them addresses a missing-authorization socket [47] (**Confirmed** mapping; the fit **Inferred**). The honest D3FEND answer for CVE-2026-123039 is Local File Permissions plus Software Update, the hotfix, which the library does not relate to these techniques [47] (**Confirmed** for the data check). The library maps no countermeasure to T1595.002, T1583.003, T1059.004, T1037, T1055, T1070, T1046, T1090, T1485 or T1491.001 [47] (**Confirmed**). See the D3FEND Reference.

## Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer pinned to ATT&CK v20, `navigator/library-layers/check-point-gaia-cve-2026-123039.json` (open in Navigator), listed on the Navigator layers page. Scores: 75 for behavior stated in the CVE record, sk1000362 or the CPR report; 50 for this study's Inferred mappings (T1133, T1037, T1036.005, T1078, T1491.001). Each technique's comment names its source numbers.

## Cross-cutting themes

- **Chains, not CVEs.** A remote flaw in a bundled language runtime and a local flaw in the vendor's own plumbing were scored separately and exploited together [1] [5] [7] (**Confirmed**). Prioritize the chain (**Inferred**).
- **The appliance is a Linux server you do not run like one.** Root daemons on local sockets, web templates the portal executes and libraries under /lib are ordinary Linux attack surface, on boxes that usually lack EDR [1] [5] (**Confirmed** facts; the EDR point **Inferred**). See the Edge Device Security Reference.
- **Disclosure trails exploitation.** Both waves came before the CVE existed [1] [5] (**Inferred**), as with CVE-2026-50751 earlier in the year, first exploited on 7 May and fixed on 8 June [51] (**Confirmed**). Hunting windows should start at first exploitation (**Inferred**).
- **Backups are part of the attack surface.** An implant that persists through backup and snapshot turns the recovery plan into a reinfection path [5] (**Inferred** from **Confirmed** capability).
- **Edge to hypervisor in one hop.** The firewall could reach ESXi over SSH, and the vCenter-managed account let it in [5] [33] (**Confirmed**). Segmentation that protects users from the internet must also protect the hypervisor from the firewall (**Inferred**).
- **Attribution is evidence-weighted, not name-weighted.** Shared keys prove shared tools, not shared operators; CPR says so and the press did not [5] [44] (**Inferred** from **Confirmed** and **Reported** sources).
- **End of support is a security state.** R81 and R81.10 are affected with no fix [3] [20] (**Confirmed**).

## Sources

All sources were opened on 13 November 2026.

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 1 | CVE Program record CVE-2026-123039 (CNA Check Point), CVE Services API; human view at cve.org | cveawg.mitre.org/api/cve/CVE-2026-123039 | 2026-11-13 | Confirmed |
| 2 | NVD, CVE-2026-123039, 2.0 API record | services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-123039 | 2026-11-13 | Confirmed |
| 3 | Check Point support article sk1000362 (CVE-2026-123039), created 8 Nov 2026, last modified 12 Nov 2026 | support.checkpoint.com/results/sk/sk1000362 | 2026-11-13 | Confirmed |
| 4 | Check Point support article sk144112, Dynamic CLI: Enhancing Gaia Clish with new Expert mode commands (public header; body needs a login) | support.checkpoint.com/results/sk/sk144112 | 2026-11-13 | Confirmed |
| 5 | Check Point Research, PHP2Shell Exploitation on Check Point Gateway, 12 Nov 2026 | research.checkpoint.com/2026/php2shell-exploitation-on-check-point-gateway/ | 2026-11-13 | Confirmed (attribution is the vendor's assessment) |
| 6 | Canadian Centre for Cyber Security, Check Point security advisory AV26-1154, 12 Nov 2026 | cyber.gc.ca/en/alerts-advisories/check-point-security-advisory-av26-1154 | 2026-11-13 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 7 | CISA, Known Exploited Vulnerabilities catalog JSON, catalog version 2026.11.13 (the 2026.11.10 version was current at publication; the feed was opened again after the 13 Nov release) | cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json | 2026-11-13 | Confirmed |
| 8 | CVE Program record CVE-2026-107484 (CNA Check Point) | cveawg.mitre.org/api/cve/CVE-2026-107484 | 2026-11-13 | Confirmed |
| 9 | ACN / CSIRT Italia, alert AL05/261109, Check Point: aggiornamenti e mitigazioni per le vulnerabilità "PHP2Shell", 9 Nov 2026 | acn.gov.it/portale/w/check-point-aggiornamenti-e-mitigazioni-per-le-vulnerabilita-php2shell- | 2026-11-13 | Confirmed |
| 10 | CERT-EU, security advisories index (including 2026-018, 23 Oct 2026) | cert.europa.eu/publications/security-advisories/ | 2026-11-13 | Confirmed |
| 11 | CERT-EU, Security Advisory 2026-012, 10 Sep 2026 | cert.europa.eu/publications/security-advisories/2026-012/ | 2026-11-13 | Confirmed |
| 12 | ESET, ESET APT Activity Report Q4 2025-Q1 2026, 28 May 2026 | welivesecurity.com/en/eset-research/eset-apt-activity-report-q4-2025-q1-2026 | 2026-11-13 | Confirmed |
| 13 | ESET, APT Activity Report Q4 2025-Q1 2026, full report PDF | web-assets.esetstatic.com/wls/en/papers/threat-reports/eset-apt-activity-report-q4-2025-q1-2026.pdf | 2026-11-13 | Confirmed |
| 14 | GreyNoise, PHP2SHELL Activity 2026 (event page, as of 13 Nov 2026 15:23 UTC) | php.events.greynoise.io | 2026-11-13 | Confirmed |
| 15 | Check Point, Gaia Administration Guide R80.10, What is Gaia | sc1.checkpoint.com/documents/R80.10/WebAdminGuides/EN/CP_R80.10_Gaia_AdminGuide/214686.htm | 2026-11-13 | Confirmed |
| 16 | Check Point, Quantum Spark FAQ, Gaia Embedded OS | sc1.checkpoint.com/documents/Appliances/Quantum_Spark_FAQ/.../Miscellaneous-Gaia-Embedded-OS.htm | 2026-11-13 | Confirmed |
| 17 | Check Point, Smart-1 Cloud Administration Guide, Overview | sc1.checkpoint.com/documents/Infinity_Portal/.../Overview.htm | 2026-11-13 | Confirmed |
| 18 | Check Point, Mobile Access Administration Guide R82.10, Getting Started | sc1.checkpoint.com/documents/R82.10/WebAdminGuides/EN/CP_R82.10_MobileAccess_AdminGuide/.../Getting-Started.htm | 2026-11-13 | Confirmed |
| 19 | Check Point support article sk98028, Jumbo Hotfix Accumulator | support.checkpoint.com/results/sk/sk98028 | 2026-11-13 | Confirmed |
| 20 | Check Point, Support Periods | checkpoint.com/services/lifecycle/support-periods.html | 2026-11-13 | Confirmed |
| 21 | Check Point, Support Life Cycle Policy | checkpoint.com/support-services/support-life-cycle-policy/ | 2026-11-13 | Confirmed |
| 22 | Check Point support article sk152052, Release Map | support.checkpoint.com/results/sk/sk152052 | 2026-11-13 | Confirmed |
| 23 | Check Point support article sk182336 (CVE-2024-24919), created 26 May 2024 | support.checkpoint.com/results/sk/sk182336 | 2026-11-13 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 24 | CISA, KEV catalog entry CVE-2024-24919 | cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2024-24919 | 2026-11-13 | Confirmed |
| 25 | CISA, KEV catalog entry CVE-2026-16232 | cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-16232 | 2026-11-13 | Confirmed |
| 26 | CVE Program record CVE-2026-50751 (CNA Check Point) | cveawg.mitre.org/api/cve/CVE-2026-50751 | 2026-11-13 | Confirmed |
| 27 | Canadian Centre for Cyber Security, Check Point security advisory AV26-902, 9 Sep 2026, updated 22 Sep 2026 | cyber.gc.ca/en/alerts-advisories/check-point-security-advisory-av26-902 | 2026-11-13 | Confirmed |
| 28 | Canadian Centre for Cyber Security, Check Point security advisory AV26-933, 17 Sep 2026 | cyber.gc.ca/en/alerts-advisories/check-point-security-advisory-av26-933 | 2026-11-13 | Confirmed |
| 29 | Check Point blog, Security Advisory: Action Required: Active Exploitation of CVE-2026-85102 and a Management Pre-Authentication Vulnerability CVE-2026-93616, 22 Sep 2026 | blog.checkpoint.com/security/security-advisory-action-required-active-exploitation-of-cve-2026-85102-... | 2026-11-13 | Confirmed |
| 30 | CVE Program record CVE-2026-93616 (CNA Check Point) | cveawg.mitre.org/api/cve/CVE-2026-93616 | 2026-11-13 | Confirmed |
| 31 | Dream Security (Dream Research blog), Chained PHP2Shell Exploit Roots 25 Servers, 26 Oct 2026, updated 29 Oct 2026 | dreamgroup.com/blog/chained-php2shell-exploit-roots-25-servers | 2026-11-13 | Reported |
| 32 | Help Net Security, Chinese hackers used VMware ESX zero-day; PHP2Shell and Fragnesia chained to root firewalls, 29 Oct 2026 | helpnetsecurity.com/2026/10/29/php2shell-fragnesia-vmware-esx-zero-day/ | 2026-11-13 | Reported |
| 33 | Mandiant (Google Cloud blog), VMware ESXi Zero-Day Used by Chinese Espionage Actor to Perform Privileged Guest Operations on Compromised Hypervisors (CVE-2023-20867, UNC3886), 13 Jun 2023 | cloud.google.com/blog/topics/threat-intelligence/vmware-esxi-zero-day-bypass | 2026-11-13 | Confirmed |
| 34 | CISA and FBI, AA25-022A, Threat Actors Chained Vulnerabilities in Ivanti Cloud Service Applications, 22 Jan 2025, revised 31 Jan 2025 | cisa.gov/news-events/cybersecurity-advisories/aa25-022a | 2026-11-13 | Confirmed |
| 35 | CISA, AA23-039A, ESXiArgs Ransomware Virtual Machine Recovery Guidance, 8 Feb 2023 | cisa.gov/news-events/cybersecurity-advisories/aa23-039a | 2026-11-13 | Confirmed |
| 36 | Broadcom, VMSA-2026-0006 (CVE-2026-41709), 29 Jul 2026, revised 19 Aug 2026 | support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/38017 | 2026-11-13 | Confirmed |
| 37 | Broadcom knowledge base 336894, Enabling or disabling Lockdown mode on an ESXi host | knowledge.broadcom.com/external/article/336894/... | 2026-11-13 | Confirmed |
| 38 | CISA, Binding Operational Directive 23-02, 13 Jun 2023 | cisa.gov/news-events/directives/binding-operational-directive-23-02 | 2026-11-13 | Confirmed |

| # | Source | URL | Opened | Grade |
|---|---|---|---|---|
| 39 | CISA, CISA Partners with ASD's ACSC, CCCS, NCSC-UK, and Other International and US Organizations to Release Guidance on Edge Devices, 4 Feb 2025 | cisa.gov/news-events/alerts/2025/02/04/... | 2026-11-13 | Confirmed |
| 40 | Canadian Centre for Cyber Security, Security considerations for edge devices (ITSM.80.101) | cyber.gc.ca/en/guidance/security-considerations-edge-devices-itsm80101 | 2026-11-13 | Confirmed |
| 41 | SigmaHQ, sigma rule repository, main tree (last commit 13 Nov 2026 08:54 UTC) | github.com/SigmaHQ/sigma | 2026-11-13 | Confirmed |
| 42 | BleepingComputer, Check Point warns of zero-day flaw exploited for root access, 13 Nov 2026 | bleepingcomputer.com/news/security/check-point-patches-zero-day-... | 2026-11-13 | Reported |
| 43 | SecurityWeek, PHP2Shell exploited in destructive Check Point gateway attacks, 13 Nov 2026 | securityweek.com/php2shell-exploited-in-destructive-check-point-gateway-attacks/ | 2026-11-13 | Reported |
| 44 | The Hacker News, Hackers Exploit PHP2Shell Flaws in Check Point Gateways to Deploy TSGA Backdoor and Wipe ESXi Files, 13 Nov 2026 | thehackernews.com/2026/11/hackers-exploit-php2shell-flaws-in.html | 2026-11-13 | Reported |
| 45 | The Hacker News, China-Linked Hackers Exploited VMware ESX Zero-Day to Reduce Audit Trail Visibility, 29 Oct 2026 | thehackernews.com/2026/10/china-linked-hackers-exploited-vmware.html | 2026-11-13 | Reported |
| 46 | Security Affairs, Unpatched Check Point Gateways Are Being Wiped exploiting PHP2Shell, 13 Nov 2026 | securityaffairs.com/202982/hacking/... | 2026-11-13 | Reported |
| 47 | TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `technique_releases.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl`, `groups.jsonl`, `group_profiles.jsonl`, `software.jsonl`, `software_profiles.jsonl`, `campaigns.jsonl` (ATT&CK v20.0) | github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack | 2026-11-13 | Confirmed |
| 48 | TeamStarWolf library data: `data/weaknesses/cwe.jsonl` and `capec.jsonl` | github.com/TeamStarWolf/TeamStarWolf/blob/main/data/weaknesses/cwe.jsonl | 2026-11-13 | Confirmed |
| 49 | TeamStarWolf library study, PHP 8.4.27 CVEs (CWE table for the PHP2Shell pair) | /case-studies/PHP_8_4_27_CVES.md | 2026-11-13 | Confirmed |
| 50 | TeamStarWolf library study, BeyondTrust Remote Support CVE-2026-1731 (Google's ARMORY CASTLE naming) | /case-studies/BEYONDTRUST_REMOTE_SUPPORT_CVE_2026_1731.md | 2026-11-13 | Reported |
| 51 | TeamStarWolf library studies, the homes for CVE-2026-50751 and for PHP2Shell: Check Point VPN IKEv1 (CVE-2026-50751) and PHP2Shell October 2026 | /case-studies/CHECK_POINT_VPN_CVE_2026_50751.md | 2026-11-13 | Confirmed |
| 52 | Team Star Wolf Intelligence Hub feed (index only; no fact rests on it) | teamstarwolf.github.io/intelligence-hub/data/feed.json | 2026-11-13 | Confirmed |

*© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.*

*© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/*

*© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/*

*© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/*

*The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.*

## Related references

- Home studies for the linked events: PHP2Shell and the October 2026 Attack Wave, Check Point VPN IKEv1 (CVE-2026-50751), PHP 8.4.27 CVEs, Thirty Days of Exposure Checks (Fragnesia)
- The 2026 edge record: Ivanti Connect Secure 2026, Ivanti EPMM CVE-2026-1281, PAN-OS CVE-2026-0257, Citrix NetScaler September 2026, FortiCloud SSO CVE-2026-24858, N-able N-central, BeyondTrust Remote Support CVE-2026-1731
- Actors and destructive operations: Threat Actors: China, Stryker Handala Wiper 2026, The Year 2023 in Intrusions (ESXiArgs), Timeline
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, Check Point, VMware ESXi, Incident Response Reference, Linux Hardening Reference, Vulnerability Management Reference, Vulnerability Prioritization Reference
- UNC5221 context in ATT&CK: C0029 Cutting Edge, S9011 BRUSHFIRE, S9012 TRAILBLAZE, S9013 DRYHOOK, S9014 PHASEJAM, S9015 BRICKSTORM, S9024 SPAWNCHIMERA
- Techniques: T1595.002, T1583.003, T1190, T1133, T1059.004, T1068, T1505.003, T1037, T1055, T1036.005, T1070, T1046, T1021.004, T1078, T1005, T1573, T1090, T1105, T1485, T1491.001
- CAPEC: CAPEC-1, CAPEC-180, CAPEC-122, CAPEC-234, CAPEC-650, CAPEC-268, CAPEC-300, CAPEC-545, CAPEC-130
- Navigator layers, including this study's layer, check-point-gaia-cve-2026-123039.json
- The Team Star Wolf Intelligence Hub
- All case studies